

else actually where he would expect gamers of this game to visit. Here is what he might post:

```

```

Can you imagine what will happen?

Every time anyone visits a page with this image embedded in it, his browser will fire off a request to the URL:

`http://awesome.strategygame.com/transfer.php?item=gold&user=hax0r&amount=10000`

This URL will try to transfer funds to our friend “hax0r” from the account of such a user. While this URL does not resolve to an image, the browser will send off a request anyway, and since it is a 1 px x 1 px image the user will not see anything.

There you have it, we got a user to without knowing it, hand over his gold to you! For this they needed to do nothing more than just visit any webpage which had this image in it. Of course they needed to be logged into the game first; however for visitors to the hacker’s profile page at the gaming site, or the gaming forums, this will be highly likely.

The web site has no way of distinguishing such a request from a genuine request, and as such they cannot block it as is. However, that does not mean there is no way to stop such attacks.

Disallowing images in the forum or in the profile page might not be what is desired. A second confirmation page is also not really a solution and might hinder the experience of the website. An example of how to hack a website that uses a confirmation page is as follows:

```
 <img id="image2" width="1" height="1" />
```

In the example given above, the first image requests a gold transfer, and when that fails – and it fails because the URL is not a valid image – it sends the confirmation using a second image. These attacks could also have been conducted via iframes.

There is a way out though, a way to protect your web application and your users from such attacks. Such attacks can be avoided by the use of a unique session or request token. Since this token would not be something that an attacker will know, and because the token will change frequently such attacks will no longer be possible.

3.2.7 Security misconfiguration